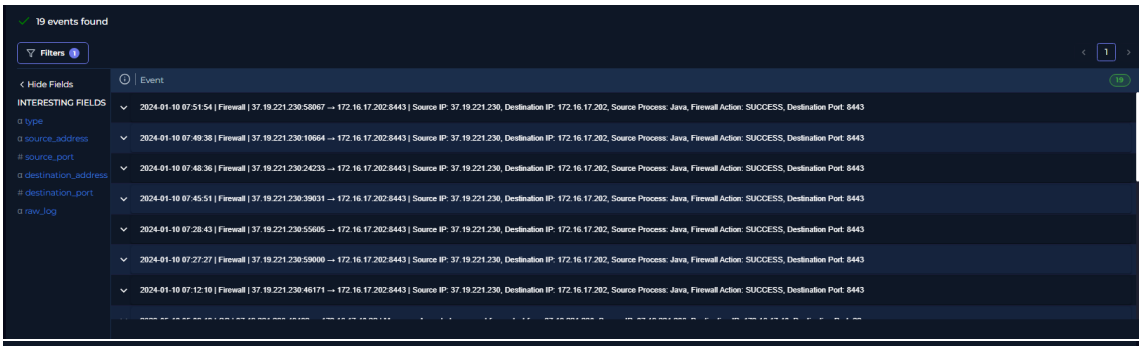
Apache OFBiz Auth Bypass and Code Injection 0-Day (CVE-2023-51467)

L1 Note :	The respective device is Ubuntu-based, hosting an Apache OFBiz Docker image. Suspicious network traffic associated with the reported zero-day vulnerability has been identified on the device. Apache OFBiz logs are located within the /ofbiz/runtime/logs directory of the relevant Docker image. Escalating to L2 for an in-depth analysis and investigation.
Hostname :	Apache OFBiz 16.11.01
User-Agent :	python-requests/2.31.0
Device Action :	Allowed
Requested URL :	/webtools/control/xmlrpc/?USERNAME=&PASSWORD=&requirePasswordChange=Y
Source IP Address :	37.19.221.230
HTTP Request Method :	POST
Alert Trigger Reason :	Anomalous activity detected during a POST request to '/webtools/control/xmlrpc/'.
Destination IP Address :	172.16.17.202

Analisando os logs



Não havia muito o que ser visto nos logs do SIEM, mas foi possível detectar que outra máquina foi alvo do mesmo IP, na outra máquina de IP 172.16.17.40 foi realizado um bruteforce bem-sucedido na porta 22

Ao prosseguir para o EDR do host web em foco foi possível analisar melhor os logs

```
92.241.218.52 - - [10/Jan/2024:13:17:36 +0000] "GET /hudson HTTP/1.1" 404 - "-" "Mozilla/5.0 zgrab/0.x"
03.56.17.252 - - [10/Jan/2024:13:21:01 +0000] "GET / HTTP/1.1" 404 - "-" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_6) AppleWebKit/537.36 (KHTML, l
e Gecko) Chrome/101.0.4951.54 Safari/537.36"
03.56.17.252 - - [10/Jan/2024:13:24:18 +0000] "GET / HTTP/1.1" 404 - "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Ge
) Chrome/101.0.4950.0 Safari/537.36"
7.19.221.230 - - [10/Jan/2024:13:27:28 +0000] "POST /webtools/control/xmlrpc/?USERNAME=&PASSWORD=&requirePasswordChange=Y HTTP/1.1" 200 245 "-" "pytho
requests/2.31.0"
7.19.221.230 - - [10/Jan/2024:13:28:44 +0000] "POST /webtools/control/xmlrpc/?USERNAME=&PASSWORD=&requirePasswordChange=Y HTTP/1.1" 200 245 "-" "pytho
requests/2.31.0"
7.19.221.230 - - [10/Jan/2024:13:45:52 +0000] "POST /webtools/control/xmlrpc/?USERNAME=&PASSWORD=&requirePasswordChange=Y HTTP/1.1" 200 245 "-" "pytho
requests/2.31.0"
7.19.221.230 - - [10/Jan/2024:13:48:37 +0000] "POST /webtools/control/xmlrpc/?USERNAME=&PASSWORD=&requirePasswordChange=Y HTTP/1.1" 200 245 "-" "pytho
requests/2.31.0"
7.19.221.230 - - [10/Jan/2024:13:49:39 +0000] "POST /webtools/control/xmlrpc/?USERNAME=&PASSWORD=&requirePasswordChange=Y HTTP/1.1" 200 245 "-" "pytho
requests/2.31.0"
7.19.221.230 - - [10/Jan/2024:13:51:55 +0000] "POST /webtools/control/xmlrpc/?USERNAME=&PASSWORD=&requirePasswordChange=Y HTTP/1.1" 200 245 "-" "pytho
requests/2.31.0"
7.19.221.230 - - [10/Jan/2024:13:52:15 +0000] "POST /webtools/control/xmlrpc/?USERNAME=&PASSWORD=&requirePasswordChange=Y HTTP/1.1" 200 245 "-" "pytho
oot@ip-172-31-33-39:/var/lib/docker/overlay2/74c57cfe85146ed5178a3bd06ec74ff8367b038337e26cac5ddda6145df9bb7d/diff/ofbiz/runtime/logs# netuser
```

Foi um ataque na autenticação vulnerável do ofbiz, o ataque provavelmente foi um sucesso já que o servidor retornou 200, isso pode ser checado analisando se há atividade suspeita no host

Image Path : /var/lib/docker/overlay2/74c57cfe85146ed5178a3bd06ec74ff8367b038337e26cac5ddda6145df9bb7d/merged/usr...
Parent Path : /var/lib/docker/overlay2/74c57cfe85146ed5178a3bd06ec74ff8367b038337e26cac5ddda6145df9bb7d/merged/usr...
Target Process Command Line : uname -a

2024-01-10 13:28:44.913000	7023	java	java	/usr/lib/jvm/java-8-openjdk-amd64/bin/java -...

Image Path : /var/lib/docker/overlay2/74c57cfe85146ed5178a3bd06ec74ff8367b038337e26cac5ddda6145df9bb7d/merged/usr...
Parent Path : /var/lib/docker/overlay2/74c57cfe85146ed5178a3bd06ec74ff8367b038337e26cac5ddda6145df9bb7d/merged/usr...
Target Process Command Line : touch /tmp/rce

2024-01-10 13:27:28.899000	7023	java	java	/usr/lib/jvm/java-8-openjdk-amd64/bin/java -...

Image Path : /var/lib/docker/overlay2/74c57cfe85146ed5178a3bd06ec74ff8367b038337e26cac5ddda6145df9bb7d/merged/usr...
Parent Path : /var/lib/docker/overlay2/74c57cfe85146ed5178a3bd06ec74ff8367b038337e26cac5ddda6145df9bb7d/merged/usr...
Target Process Command Line : /bin/bash touch /tmp/rce

2024-01-10 13:48:37.618000	7023	java	java	/usr/lib/jvm/java-8-openjdk-amd64/bin/java -...

Image Path : /var/lib/docker/overlay2/74c57cfe85146ed5178a3bd06ec74ff8367b038337e26cac5ddda6145df9bb7d/merged/usr...
Parent Path : /var/lib/docker/overlay2/74c57cfe85146ed5178a3bd06ec74ff8367b038337e26cac5ddda6145df9bb7d/merged/usr...
Target Process Command Line : cat /etc/passwd

Processes 19 | Network Action | Terminal History | Browser History | Results: 10

EVENT TIME	PROCESS ID	PROCESS NAME	PARENT PROCESS	COMMAND LINE
2024-01-10 13:52:15.866000	7023	java	java	/usr/lib/jvm/java-8-openjdk-amd64/bin/java -...
2024-01-10 13:51:55.810000	9222	perl	java	/usr/bin/perl /usr/sbin/adduser h4xops sudo

Image Path : /var/lib/docker/overlay2/74c57cfe85146ed5178a3bd06ec74ff8367b038337e26cac5ddda6145df9bb7d/merged/usr...
Parent Path : /var/lib/docker/overlay2/74c57cfe85146ed5178a3bd06ec74ff8367b038337e26cac5ddda6145df9bb7d/merged/usr...
Target Process Command Line : /usr/bin/gpasswd -a h4xops sudo

2024-01-10 13:51:55.759000	7023	java	java	/usr/lib/jvm/java-8-openjdk-amd64/bin/java -...
2024-01-10 13:49:39.532000	7023	java	java	/usr/lib/jvm/java-8-openjdk-amd64/bin/java -...

Image Path : /var/lib/docker/overlay2/74c57cfe85146ed5178a3bd06ec74ff8367b038337e26cac5ddda6145df9bb7d/merged/usr...
Parent Path : /var/lib/docker/overlay2/74c57cfe85146ed5178a3bd06ec74ff8367b038337e26cac5ddda6145df9bb7d/merged/usr...
Target Process Command Line : useradd h4xops

Pelo que foi possível analisar ele criou um arquivo chamado “rce” no /tmp, utilizou comandos de reconhecimento como whoami, “cat/etc/passwd”, também criou um usuário camado h4xops e o adicinou no grupo sudo

```
root@ip-172-31-33-39:/var/lib/docker/overlay2/74c57cfe85146ed5178a3bd06ec74ff8367b038337e26cac5ddda6145df9bb7d/diff/ofbiz/runtime/logs# id h4xops
id: ‘h4xops’: no such user
root@ip-172-31-33-39:/var/lib/docker/overlay2/74c57cfe85146ed5178a3bd06ec74ff8367b038337e26cac5ddda6145df9bb7d/diff/ofbiz/runtime/logs#
```

Ao verificar esse usuário não existia, provavelmente não obteve sucesso

```
root@ip-172-31-33-39:/home/ubuntu# ufw status
Status: inactive
root@ip-172-31-33-39:/home/ubuntu#
```

Ao verificar o firewall estava desativado, mas não havia logs no audit.log e não foi possível determinar no auth.log também

1 / 92
Community Score

1/92 security vendor flagged this IP address as malicious

Reanalyze | More

37.19.221.230 (37.19.220.0/23)
AS 212238 (Datacamp Limited)
vpn

US
Last Analysis Date
6 days ago

DETECTION | DETAILS | RELATIONS | COMMUNITY

O IP do atacante não tem histórico de ser malicioso

T1190 - Exploit Public-Facing Application

T1136 - Create Account

T1562 - Impair Defenses

Horário:

10/Jan/2024 13:27:28

IoC:

Endereço IP:

37.19.221.230

Conta criada:

h4xops

Análise:

O invasor utilizou de uma vulnerabilidade de autenticação do OFBiz para obter controle do servidor WEB de IP 172.16.17.202, por cerca do mesmo horário um pouco antes ele foi bem sucedido em um bruteforce na porta 22 na máquina de IP 172.16.17.40, depois de obter acesso ao servidor web ele utulizou comandos de reconhecimento como “whoami”, criou um arquivo /tmp/rce e também um usuário o adicionando no grupo sudo logo em seguida, não havia logs comprovando isso, mas ele também parece ter desativado o firewall.

Recomendações:

- Atualizar o OFBiz para a última versão
- Não permitir comandos que não sejam necessários para a conta que o servidor web utiliza, como criação de usuário ou ler arquivos de fora do seu diretório como /etc/passwd

- Para a outra máquina comprometida utilizar uma política de senhas bem estruturada
- Não expor protocolos de controle remoto para a rede pública caso não for realmente necessário